SysMap Solutions

Software e Consultoria Ltda.

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

PSI — Versão 1.0

Classificação:	**CONFIDENCIAL**
Data de emissão:	Março de 2026
Próxima revisão:	Março de 2027
Elaborado por:	Comitê de Segurança da Informação
Aprovado por:	Diretoria Executiva — SysMap Solutions

1. Identificação da Organização

A SysMap Solutions Software e Consultoria Ltda. é uma empresa brasileira de tecnologia fundada em 1999, sediada em São Paulo/SP, com mais de 25 anos de experiência em transformação digital, desenvolvimento de software, consultoria em nuvem e integração de sistemas. A empresa atende clientes nos segmentos de Telecom, Varejo, Financeiro, Educação, Energia e Indústria em toda a América Latina.

1.1 Dados Corporativos

Razão Social	SysMap Solutions Software e Consultoria Ltda.
Segmento	Consultoria em TI / Transformação Digital / Cloud
Colaboradores	500 – 1.000 colaboradores (diretos e alocados)
Sede principal	Rua Des. Eliseu Guilherme, 200, 11º andar — Paraíso, São Paulo/SP
Filial	Av. Dr. Chucri Zaidan, 920 — Vila São Francisco, São Paulo/SP
Infraestrutura cloud	Microsoft Azure (tenant principal) — região Brazil South + East US
Produtividade & colaboração	Microsoft 365 (Exchange Online, Teams, SharePoint, OneDrive, Intune)
Identidade & acesso	Microsoft Entra ID (Azure AD) com MFA e Conditional Access
Segurança	Microsoft Defender for Cloud, Defender for Endpoint, Sentinel (SIEM)
DevOps & repositórios	Azure DevOps + GitHub Enterprise (org SysMap)
Conformidade	LGPD (Lei 13.709/2018) — DPO nomeado

2. Objetivo e Escopo da Política

Esta Política de Segurança da Informação (PSI) estabelece as diretrizes, normas e responsabilidades necessárias para proteger os ativos de informação da SysMap Solutions e de seus clientes, preservando a Tríade CID — Confidencialidade, Integridade e Disponibilidade — sobre toda a infraestrutura Microsoft 365 e Azure.

Tríade CID — Pilares desta Política

CONFIDENCIALIDADE — Dados de clientes, projetos e colaboradores acessados somente por pessoas autorizadas, protegidos via Entra ID, Conditional Access e Microsoft Purview.
INTEGRIDADE — Informações íntegras e rastreáveis; alterações somente por processos autorizados, auditadas no Microsoft Purview Compliance Center.
DISPONIBILIDADE — Serviços Azure e M365 com SLA mínimo de 99,9%; arquitetura multi-região com Azure Site Recovery e backup imutável.

2.1 Escopo de Aplicação

Esta política aplica-se a:

- Todos os colaboradores, estagiários, prestadores de serviço (body shop, squads alocados) e parceiros com acesso ao ambiente SysMap
- Todo o tenant Microsoft 365 (Exchange Online, Teams, SharePoint, OneDrive, Intune) e as subscriptions Azure
- Repositórios de código em Azure DevOps e GitHub Enterprise
- Dispositivos corporativos e BYOD registrados no Microsoft Intune
- Instalações físicas: sede e filiais em São Paulo, salas de servidor e home office

2.2 Normas e Legislação de Referência

- ABNT NBR ISO/IEC 27001:2022 — Gestão de segurança da informação
- ABNT NBR ISO/IEC 27002:2022 — Controles de segurança
- Lei Geral de Proteção de Dados — LGPD (Lei 13.709/2018)
- Microsoft Cloud Security Benchmark (MCSB) v1
- NIST Cybersecurity Framework v2.0
- CIS Controls v8

3. Ativos e Ambientes Críticos Protegidos

3.1 Infraestrutura Física

Local	Classificação	Controles Físicos e Lógicos
Sala de Servidores — SP Paraíso	CRÍTICO	Acesso biométrico + CFTV 24h + controle de temperatura + nobreak + gerador
Escritório Filial — SP Cidade Monções	RESTRITO	Crachá eletrônico + câmera + política de mesa limpa + inventário de ativos
Home Office / Trabalho Remoto	CONTROLADO	VPN Azure obrigatória + Intune Compliance Policy + MFA + tela bloqueada
Ambiente Azure (Brazil South)	CRÍTICO	Azure Security Center + NSG + Private Endpoints + RBAC + Defender for Cloud
Azure DevOps / GitHub Enterprise	CRÍTICO	MFA obrigatório + branch policies + secret scanning + auditoria de commits

3.2 Classificação de Dados

Níveis de Classificação da Informação (Microsoft Purview Sensitivity Labels)

 CONFIDENCIAL — Dados de clientes, contratos, credenciais, código-fonte proprietário. Criptografia automática + acesso restrito.
 RESTRITO — Informações internas de projetos, dados financeiros, comunicações estratégicas. Acesso por equipe definida.
 INTERNO — Documentos corporativos gerais, procedimentos internos. Acesso a todos os colaboradores.
 PÚBLICO — Materiais de marketing, conteúdo publicado no site. Sem restrições.

4. Estrutura de Governança de Segurança

Papel / Responsável	Responsabilidades	Escopo
Comitê de SI (CSI)	Aprovação de políticas, revisão anual, gestão de incidentes críticos	Diretor de TI, CISO, Jurídico, RH, Gerência de Projetos
CISO	Implantação, monitoramento e melhoria contínua da PSI	Cargo dedicado; reporta à Diretoria Executiva
Gestor de TI / Cloud	Administração do tenant M365, Azure subscriptions, controle de acessos	Equipe de Cloud & Infra (analistas sênior)
DPO — Encarregado LGPD	Conformidade LGPD, atendimento a titulares, interface com ANPD	Cargo dedicado; reporta ao Jurídico
Tech Leads / Architects	Garantir práticas de segurança em projetos e squads	Todos os projetos ativos
Colaboradores e terceiros	Cumprir normas, reportar incidentes, completar treinamentos	Todos com acesso ao ambiente SysMap

5. Análise de Riscos

5.1 Metodologia

A análise de riscos seguiu a metodologia da ABNT NBR ISO/IEC 27005:2023, com matriz Probabilidade × Impacto. Os riscos foram identificados por meio de revisão do Microsoft Secure Score, análise de logs no Microsoft Sentinel, entrevistas com Tech Leads e pela execução de pentest externo em fevereiro de 2026.

5.2 Matriz de Riscos — Ecossistema Microsoft

ID	Ameaça / Risco	Probab.	Impacto	Controles (Ecossistema Microsoft)	Risco Residual
R01	Comprometimento de conta M365 / Entra ID	Alta	Crítico	MFA via Microsoft Authenticator + Conditional Access + Privileged Identity Management	Médio
R02	Ataque de ransomware aos ambientes Azure	Média	Crítico	Azure Backup imutável + Microsoft Defender for Cloud + segmentação via VNet	Baixo
R03	Phishing via e-mail corporativo (Exchange Online)	Alta	Alto	Microsoft Defender for Office 365 (ATP) + Safe Links + Safe Attachments + treinamento	Médio
R04	Vazamento de dados de clientes por colaborador	Média	Crítico	Microsoft Purview DLP + Information Protection + auditoria via Compliance Center	Médio
R05	Acesso indevido a repositórios (Azure DevOps / GitHub)	Média	Alto	RBAC granular + branch protection + revisão de código obrigatória + secret scanning	Baixo

ID	Ameaça / Risco	Probab.	Impacto	Controles (Ecossistema Microsoft)	Risco Residual
R06	Falha ou indisponibilidade de serviços Azure	Baixa	Alto	Arquitetura multi-região + SLA 99,9% + Azure Site Recovery + monitoramento Azure Monitor	Baixo
R07	Vulnerabilidades em aplicações desenvolvidas	Alta	Médio	Microsoft Defender for DevOps + SAST/DAST no pipeline CI/CD + pentest semestral	Médio
R08	Perda de dispositivo corporativo ou BYOD	Média	Médio	Microsoft Intune MDM + BitLocker + wipe remoto via Entra ID + Conditional Access	Baixo
R09	Acesso remoto não seguro (home office / cliente)	Alta	Alto	VPN Azure + Entra ID Conditional Access + Intune compliance policy	Médio
R10	Exposição não intencional de recursos Azure	Média	Alto	Azure Policy + Microsoft Defender CSPM + revisão mensal de permissões IAM	Baixo

6. Controle de Identidade e Acesso (IAM)

6.1 Microsoft Entra ID — Autenticação

- MFA obrigatório para todos os usuários via Microsoft Authenticator (push notification ou TOTP)
- Passwordless habilitado para equipes de TI e liderança (FIDO2 / Windows Hello for Business)
- Políticas de Acesso Condicional (Conditional Access): bloqueio de acesso fora de dispositivos gerenciados pelo Intune
- Entra ID Protection: detecção automática de logins de risco, senhas vazadas e anomalias comportamentais
- Self-Service Password Reset (SSPR) habilitado com verificação em dois passos

6.2 Princípio do Menor Privilégio e RBAC

Todas as permissões no M365 e Azure seguem o princípio do menor privilégio. Acessos privilegiados são gerenciados pelo Microsoft Entra Privileged Identity Management (PIM):

- Roles administrativas (Global Admin, Subscription Owner) ativadas sob demanda (Just-in-Time) com aprovação do CISO
- Revisão trimestral de permissões via Entra ID Access Reviews
- Contas de serviço e automação utilizam Managed Identities (sem senhas armazenadas em código)
- Offboarding: conta desativada imediatamente no Entra ID e acesso aos grupos revogado em até 2 horas
- Proibido compartilhamento de credenciais; cada colaborador possui conta nominal e intransferível

7. Proteção e Criptografia de Dados

7.1 Microsoft Purview — Governança de Dados

- Sensitivity Labels configuradas no Microsoft Purview Information Protection aplicadas a e-mails, documentos SharePoint e OneDrive
- Políticas de DLP (Data Loss Prevention) bloqueiam envio de dados de clientes por e-mail externo não autorizado, Teams ou upload para serviços cloud não aprovados
- Retenção automática de e-mails e arquivos conforme política de retenção por tipo de dado (mínimo 5 anos para contratos)
- Microsoft Purview Audit (Unified Audit Log) retém logs de acesso e modificação por 90 dias (P1) ou 1 ano (P2)

7.2 Criptografia

- Dados em trânsito: TLS 1.2+ obrigatório em todas as comunicações; HTTPS forçado em todos os recursos Azure
- Dados em repouso: Azure Storage Service Encryption (SSE) com chaves gerenciadas pelo cliente (CMK) via Azure Key Vault
- Chaves criptográficas armazenadas no Azure Key Vault com acesso restrito ao CISO e ao time Cloud; rotação anual automática
- BitLocker habilitado em todos os dispositivos Windows gerenciados pelo Intune; FileVault em macOS
- Secrets, connection strings e API keys proibidos em código-fonte; gerenciados exclusivamente via Azure Key Vault + referências seguras no pipeline

7.3 Conformidade com a LGPD

- Dados pessoais de colaboradores e parceiros mapeados no catálogo do Microsoft Purview Data Map
- Pedidos de titulares (acesso, correção, exclusão) atendidos pelo DPO em até 15 dias
- Relatório de Impacto à Proteção de Dados (RIPD) elaborado para todo novo projeto que envolva dados pessoais
- Transferências internacionais de dados avaliadas e documentadas antes de qualquer integração com sistemas externos

8. Backup, Continuidade de Negócios e Recuperação

8.1 Estratégia de Backup no Azure

Estratégia 3-2-1 em Azure

3 cópias dos dados | 2 tipos de armazenamento (Azure Backup + Azure Blob Storage imutável) | 1 cópia em região remota (East US)

- Azure Backup configurado para VMs, SQL Databases e Azure Files — retenção mínima 30 dias (diário), 12 semanas (semanal), 12 meses (mensal)
- Soft delete habilitado no Azure Backup com período de proteção de 14 dias contra exclusão acidental ou maliciosa

- Backups de repositórios Azure DevOps e GitHub exportados semanalmente para Azure Blob Storage imutável (WORM — Write Once Read Many)
- Testes de restauração executados mensalmente; resultado documentado no Compliance Center
- Microsoft 365 Backup ativo para Exchange Online, SharePoint e OneDrive (retenção 1 ano)

8.2 Plano de Continuidade e Recuperação (BCP/DRP)

- RTO (Recovery Time Objective): máximo 4 horas para serviços críticos (ambientes de produção de clientes)
- RPO (Recovery Point Objective): máximo 1 hora de perda de dados tolerável
- Azure Site Recovery (ASR) configurado para replicação contínua de VMs críticas para região East US
- Simulacro de desastre realizado semestralmente com registro de lições aprendidas
- Plano de comunicação de crise ativado pelo CISO via Microsoft Teams (canal dedicado Incident Response) em até 30 minutos

9. Segurança de Rede e Infraestrutura Azure

- Segmentação de rede via Azure Virtual Networks (VNets) com sub-redes separadas para produção, desenvolvimento, staging e administração
- Network Security Groups (NSGs) e Azure Firewall Premium com regras de negar-por-padrão em todos os recursos públicos
- Private Endpoints para todos os serviços Azure PaaS (Storage, SQL, Key Vault, Container Registry) — sem exposição à internet pública
- Microsoft Defender for Cloud habilitado em todas as subscriptions com postura de segurança monitorada pelo Secure Score
- Microsoft Sentinel (SIEM/SOAR) com monitoramento 24x7, playbooks automatizados de resposta a incidentes e integração com Defender XDR
- Gestão de vulnerabilidades: Microsoft Defender Vulnerability Management com remediação priorizada por CVSS; patches críticos aplicados em até 48 horas
- Pentest externo semestral conduzido por empresa especializada; relatório compartilhado com CSI
- Acesso remoto a recursos internos somente via Azure VPN Gateway com MFA + Conditional Access verificado

10. Segurança no Ciclo de Desenvolvimento (DevSecOps)

A SysMap integra práticas de segurança em todo o ciclo de vida do desenvolvimento (SDLC), conforme o modelo DevSecOps com ferramentas nativas do ecossistema Microsoft:

- Microsoft Defender for DevOps integrado ao Azure DevOps e GitHub Enterprise para análise de código (SAST) em cada pull request
- GitHub Advanced Security: secret scanning, code scanning e dependency review habilitados em todos os repositórios
- Branch protection obrigatória: toda alteração em branches main/master exige aprovação de no mínimo 1 revisor + pipeline CI/CD aprovado

- Análise de composição de software (SCA): dependências de terceiros verificadas automaticamente contra CVEs conhecidos
- Ambientes de desenvolvimento e teste utilizam dados pseudonimizados — proibido uso de dados reais de clientes nesses ambientes
- Revisão de segurança obrigatória (Threat Modeling) antes do início de cada novo projeto ou funcionalidade de alto risco
- Secrets, tokens e credenciais gerenciados via Azure Key Vault; proibido hardcoding em qualquer camada

11. Regras de Conduta para Colaboradores

11.1 Uso Aceitável dos Recursos Microsoft 365

Os recursos corporativos (Exchange Online, Teams, SharePoint, OneDrive, dispositivos gerenciados pelo Intune) são de uso exclusivamente profissional. São terminantemente proibidos:

- Compartilhar ou repassar credenciais corporativas (senha, token MFA) a qualquer pessoa
- Armazenar dados de clientes fora dos sistemas aprovados (ex.: envio para e-mail pessoal ou upload para Google Drive/Dropbox)
- Instalar aplicativos não aprovados pelo catálogo do Intune Company Portal ou sem autorização do TI
- Desabilitar ou contornar políticas de segurança gerenciadas pelo Intune (BitLocker, tela de bloqueio, MDM enrollment)
- Acessar recursos de clientes sem permissão documentada e aprovada pelo gestor do projeto
- Usar IA generativa ou ferramentas externas para processar dados confidenciais de clientes

11.2 Dispositivos Móveis e BYOD

- Dispositivos corporativos gerenciados exclusivamente via Microsoft Intune
- BYOD (celular ou tablet pessoal) permitido somente mediante registro no Intune e aceite do perfil de gerenciamento
- Bloqueio automático de tela após 5 minutos; PIN mínimo de 6 dígitos ou biometria
- Wipe remoto acionado pelo TI em caso de perda, roubo ou desligamento

11.3 Trabalho Remoto

- Azure VPN obrigatória para acesso a recursos internos e sistemas de clientes — sem exceções
- Proibido acessar sistemas corporativos em redes Wi-Fi públicas (aeroportos, cafés, hotéis) sem VPN ativa
- Política de mesa limpa e tela limpa: bloqueio imediato ao sair do computador (Windows + L)
- Videoconferências pelo Microsoft Teams; plataformas externas não aprovadas requerem autorização prévia

11.4 Phishing e Engenharia Social

- Nunca fornecer senha, código MFA ou dados de clientes por telefone, e-mail ou Teams, mesmo para quem se identifique como TI ou gestão
- E-mails ou mensagens suspeitas devem ser reportados via botão 'Reportar Phishing' do Microsoft Outlook (Microsoft Report Message add-in)
- Simulações de phishing realizadas trimestralmente via Microsoft Attack Simulator; colaboradores que clicam são encaminhados para treinamento obrigatório

12. Treinamento e Conscientização

- Treinamento inicial obrigatório: módulo de PSI e segurança M365 concluído nos primeiros 5 dias úteis (Microsoft Viva Learning)
- Reciclagem anual obrigatória com avaliação; aprovação mínima de 80%
- Campanhas mensais de conscientização via Microsoft Viva Engage e e-mail corporativo
- Microsoft Security Awareness Training (via Defender for Office 365) com simulações automatizadas
- Treinamentos específicos para equipes de Cloud & Infra: Microsoft Azure Security Engineer (AZ-500) incentivado como certificação
- Registro de capacitações integrado ao Microsoft Viva Learning para fins de auditoria

13. Gestão de Incidentes de Segurança

13.1 Classificação e Tempo de Resposta

Nível	Descrição	Exemplo no Ambiente SysMap	Resposta
P1 — CRÍTICO	Comprometimento confirmado ou indisponibilidade total	Conta Entra ID comprometida + exfiltração; ransomware em VMs Azure	< 15 min — CISO + Equipe Cloud + Jurídico
P2 — ALTO	Degradação significativa ou atividade suspeita de alto risco	Alerta de Sentinel indicando movimento lateral; DDoS em recurso Azure	< 1 hora — CISO + TI
P3 — MÉDIO	Incidente limitado sem impacto direto em produção	Phishing clicado; malware isolado no Defender for Endpoint	< 4 horas — Equipe de TI
P4 — BAIXO	Não conformidade ou evento menor	Política Intune descumprida; senha fraca detectada	< 24 horas — Analista TI

13.2 Processo de Resposta — Microsoft Sentinel

- Alertas gerados automaticamente pelo Microsoft Sentinel (SIEM) são triados pelo time de TI 24x7
- Playbooks automatizados (Logic Apps) executam isolamento de VM, revogação de conta ou bloqueio de IP conforme o tipo de incidente

- Todos os incidentes P1 e P2 documentados no Microsoft Defender portal (Incident queue) com registro de timeline e evidências
- Post-mortem obrigatório em até 5 dias úteis após resolução de incidentes P1 e P2; resultados apresentados ao CSI

13.3 Notificação à ANPD (LGPD)

Incidentes que envolvam dados pessoais com risco relevante aos titulares devem ser notificados à ANPD em até 72 horas após a ciência, conforme Art. 48 da LGPD. O DPO é responsável por coordenar a notificação em conjunto com o CISO e o Jurídico.

14. Sanções pelo Descumprimento

O descumprimento desta política sujeita o infrator às medidas disciplinares abaixo, assegurados contraditório e ampla defesa:

Gravidade	Exemplos de Infração	Penalidade
Leve	Não bloquear a tela; usar Teams para fins pessoais excessivamente	Advertência verbal + novo treinamento obrigatório
Moderada	Compartilhar senha; conectar BYOD sem registro no Intune	Advertência formal escrita + suspensão temporária de acessos
Grave	Enviar dados de clientes para e-mail pessoal; instalar software não autorizado intencionalmente	Suspensão + possível demissão por justa causa + notificação ao Jurídico
Gravíssima	Venda de dados de clientes; sabotagem de sistemas; espionagem corporativa	Demissão imediata + registro policial + ação civil e/ou criminal perante a ANPD

Violações envolvendo dados pessoais de clientes podem gerar responsabilização individual do colaborador perante a ANPD e o Poder Judiciário, independentemente das sanções internas.

15. Revisão e Vigência

- Esta política entra em vigor em 01/03/2026 com validade de 12 meses
- Revisão ordinária: março de 2027, conduzida pelo CSI
- Revisão extraordinária: após incidente grave (P1/P2), mudança regulatória significativa ou reestruturação relevante da infraestrutura Azure/M365
- Alterações aprovadas pelo CSI comunicadas a todos os colaboradores em até 5 dias úteis via Microsoft Viva Engage e e-mail corporativo
- Versão atual mantida no SharePoint corporativo (canal de Segurança) com controle de versão habilitado

Aceite da Política

Ao receber acesso ao ambiente SysMap Solutions (tenant M365, Azure, Azure DevOps ou GitHub Enterprise), o colaborador ou prestador declara ter lido, compreendido e concordado com todas as diretrizes desta PSI. O aceite é registrado eletronicamente no onboarding via Microsoft Entra ID Terms of Use.